

Лабораторна робота 2

Дослідження процесів проникнення та OSINT-розвідки

Завдання 1. Аналіз та оцінка експерименту Вінклера

Описаний експеримент є показовим прикладом атаки на основі соціальної інженерії. Жодного технічного злому не відбулося: зловмисники діяли виключно через телефонні дзвінки та загальнодоступну інформацію. Ланцюжок атаки вибудовувався поступово: кожен крок давав дані для наступного. Схема проникнення виглядала так: відкриті джерела надали імена і структуру компанії, телефонний довідник уточнив посади, розсилання і відділ кадрів розкрили особисті номери, а нові співробітники, яких обдурили, передали логіни й паролі.

Оцінка вразливостей:

- Відсутня будь-яка процедура перевірки особистості при телефонному запиті
- Щорічний звіт містив надмірно детальну організаційну інформацію
- Нові співробітники не пройшли базовий інструктаж з безпеки до моменту отримання доступів
- Культура безпеки в організації фактично була відсутня: ніхто не запідозрив нічого незвичного
- Паролі передавалися по телефону без жодного сумніву

Висновок: найслабшою ланкою виявився людський фактор. Технічні засоби захисту без відповідної підготовки персоналу не здатні протистояти соціальній інженерії.

Завдання 2. Комплекс заходів з розробки та впровадження політики безпеки

2.1. Організаційні заходи

Щодо телефонних запитів та передачі інформації:

- Встановити правило: паролі та облікові дані не передаються по телефону ні за яких обставин, навіть на запит ІТ-відділу

					ДУ «Житомирська політехніка».26.121.20.000 – Лр2			
Змн.	Арк.	№ докум.	Підпис	Дата				
Розроб.		Риженко Я.В.			Звіт з лабораторної роботи		Лім.	Арк.
Перевір.		Лобанчикова Н.М.						1
Керівник								8
Н. контр.							ФІКТ Гр. ІПЗ-23-1	
Зав. каф.								

- Запровадити процедуру зворотного дзвінка: перш ніж надати будь-яку чутливу інформацію, потрібно перетелефонувати за офіційним внутрішнім номером для підтвердження особи
- Розробити систему кодових фраз між відділами для верифікації при нетипових запитах

Щодо нових співробітників:

- Проводити обов'язковий інструктаж з інформаційної безпеки в перший робочий день, до видачі будь-яких доступів
- Призначати наставника, який пояснює регламент взаємодії з ІТ та іншими підрозділами
- Чітко роз'яснювати, яку інформацію заборонено повідомляти стороннім особам

Щодо публічної інформації:

- Обмежити деталізацію організаційної структури в щорічних звітах та корпоративних матеріалах
- Не публікувати повні імена та посади рядових співробітників у відкритому доступі

2.2. Технічні заходи

- Двофакторна автентифікація для всіх корпоративних систем
- Система тікетів для ІТ-запитів замість усних і телефонних звернень
- Логування запитів на зміну паролів з обов'язковим підтвердженням через офіційний канал
- Принцип мінімальних привілеїв: кожен співробітник має доступ лише до необхідних ресурсів

2.3. Процедурні заходи

- Регулярні навчання персоналу з протидії соціальній інженерії (не рідше одного разу на рік)
- Планові симуляційні тести: фішинг, вішинг, імітація зовнішніх дзвінків
- Обов'язкова процедура звітування про підозрілі дзвінки та запити

		Рижченко Я.В.			ДУ «Житомирська політехніка».26.121.20.000 – Лр2	Арк.
		Лобанчикова Н.М.				
Змн.	Арк.	№ докум.	Підпис	Дата		2

- Регламент, що визначає, хто, кому і яку інформацію має право надавати

Завдання 3. Реалізація окремих аспектів експерименту

У рамках навчального завдання було змодельовано перший етап атаки: збір відкритої інформації про компанію Foxtrot без жодного прямого контакту з її співробітниками. Використовувалися виключно загальнодоступні джерела.

Проведені дії:

- Пошук за запитамі «Foxtrot Україна», «Foxtrot керівництво», «Foxtrot структура компанії» у Google
- Аналіз офіційного сайту foxtrot.com.ua: розділи «Про компанію», контактна інформація, перелік магазинів і регіональна мережа
- Перегляд публічних матеріалів: прес-релізів на сайті, статей у ЗМІ (Forbes Ukraine, Mind.ua, Delo.ua), інтерв'ю з топ-менеджерами
- Аналіз сторінок компанії у соціальних мережах: Facebook, Instagram, LinkedIn публікації, відмітки локацій, згадки співробітників
- Пошук вакансій на work.ua та rabota.ua: назви посад, відділів, вимоги до кандидатів, що дозволяють реконструювати внутрішню структуру

Знайдена інформація:

- Повна назва юридичної особи та форма власності
- Імена окремих топ-менеджерів та публічних представників компанії з інтерв'ю та прес-релізів
- Географія офісів і розподільчих центрів
- Структура відділів, що частково розкривається через активні вакансії
- Корпоративна електронна пошта у форматі, що може бути виявлений через відкриті звернення

З отриманої інформації вдалося скласти загальне уявлення про організаційну структуру компанії та імена частини персоналу - без жодного технічного втручання чи прямого контакту. Це наочно демонструє реальну загрозу від надмірно відкритих корпоративних даних у публічному просторі.

		Рижченко Я.В.			ДУ «Житомирська політехніка».26.121.20.000 – Пр2	Арк.
		Лобанчикова Н.М.				3
Змн.	Арк.	№ докум.	Підпис	Дата		

Завдання 4. OSINT-розвідка по власних даних

Для самодослідження використано такі інструменти:

Інструмент	Що перевірялося	Адреса
WhatsMyName	Нікнейм DDXwild	whatsmyname.app
HaveIBeenPwned	ipz231_ryav@student.ztu.edu.ua	haveibeenpwned.com
Epieos	ipz231_ryav@student.ztu.edu.ua	epieos.com
Google Dorks	Згадки в мережі	Пошук за ім'ям та нікнеймом
Wayback Machine	Архівні сторінки	Перевірка архівних версій

Результати роботи з кожним інструментом зафіксовано у вигляді скріншотів.

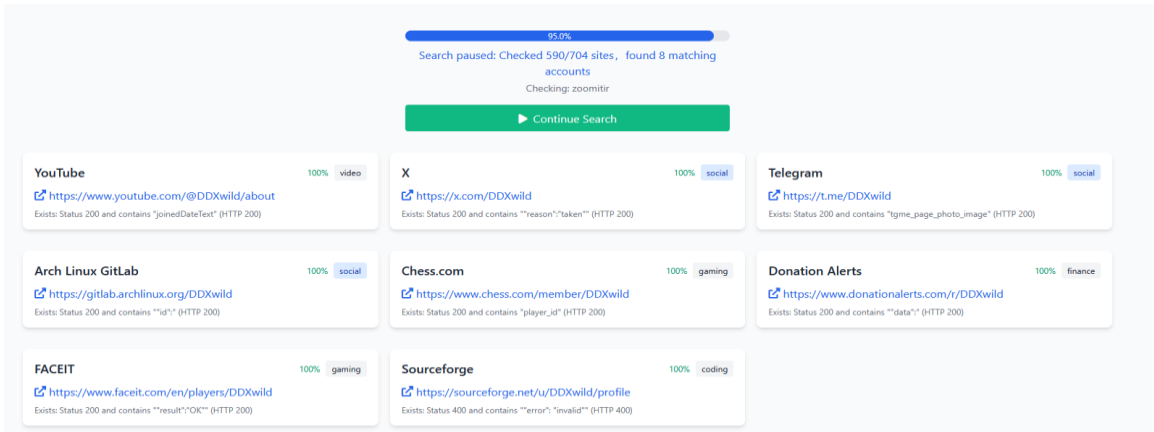


Рис. 1. Результат перевірки на сайті whatsmyname.app за нікнеймом DDXwild.

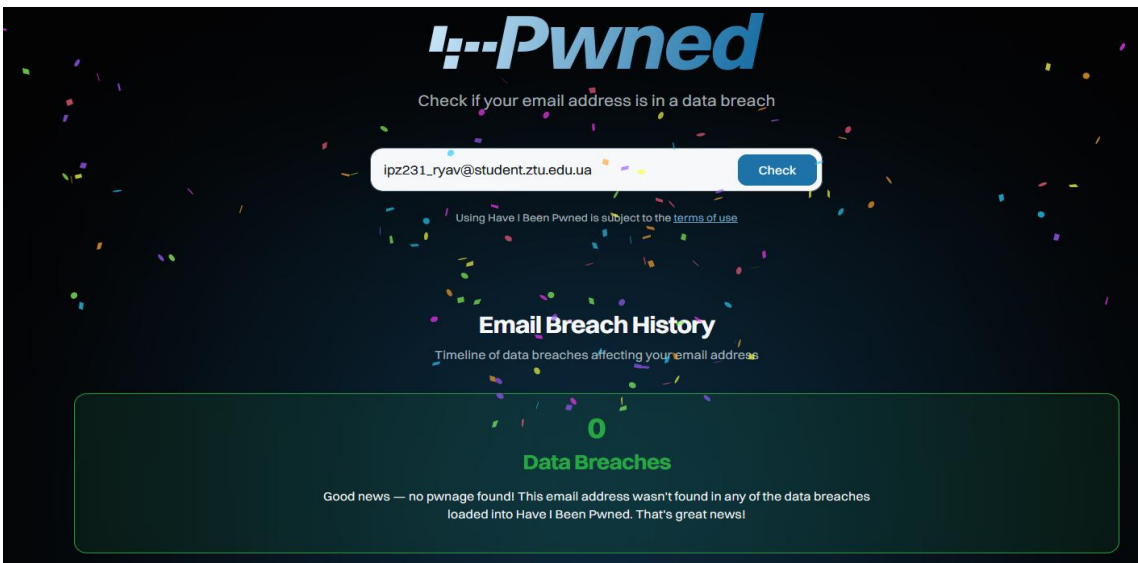


Рис. 2. Результат перевірки на сайті haveibeenpwned.com за поштою університету.

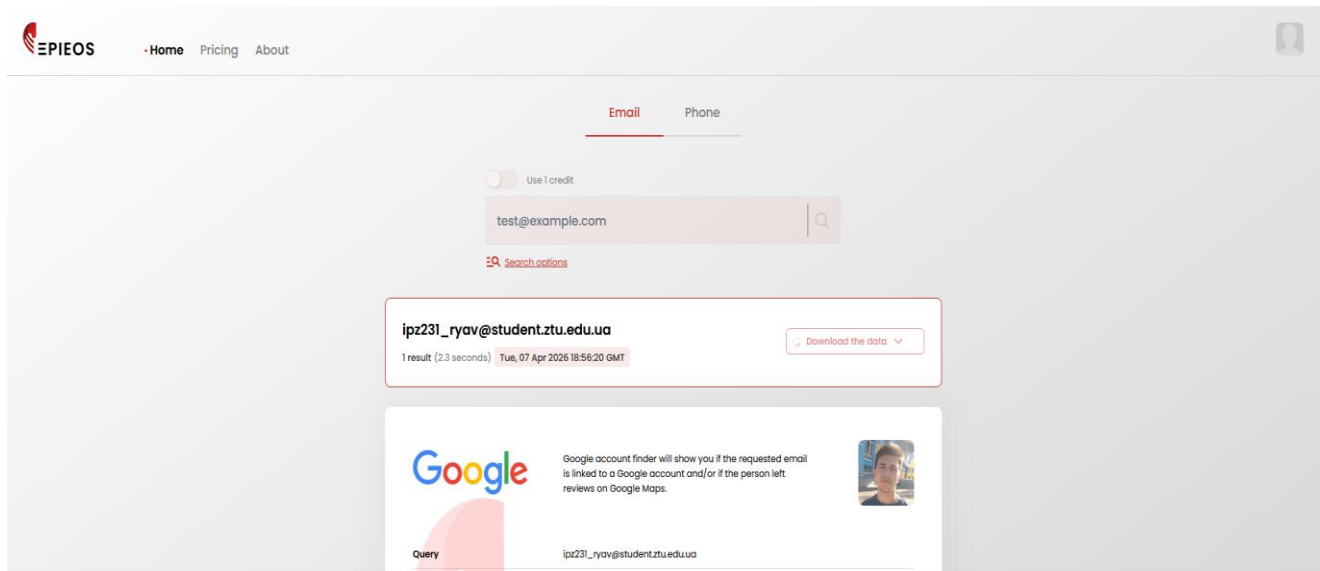


Рис. 3. Результат перевірки на сайті еріеос.com за поштою університету.

За допомогою WhatsMyName виявлено 8 акаунтів під нікнеймом DDXwild на таких платформах: YouTube, X (Twitter), Telegram, Arch Linux GitLab, Chess.com, Donation Alerts, FACEIT, Sourceforge. Це свідчить про широку присутність у різних категоріях платформ - соціальні мережі, ігрові сервіси, фінансові та кодингові платформи. Перевірка через HaveIBeenPwned показала позитивний результат: електронна адреса не фігурує в жодному відомому витoku даних (0 Data Breaches). Інструмент Еріеос виявив прив'язку email-адреси до Google-акаунту з фотографією профілю, що підтверджує реальну особу за адресою.

Оцінка: цифровий слід є помірно широким. Нікнейм DDXwild присутній на 8 різнотипних платформах, що дозволяє скласти досить детальний профіль особи: ігрові вподобання (FACEIT, Chess.com), технічні інтереси (GitLab, Sourceforge), наявність стрімінгової діяльності (Donation Alerts). Email не компрометований у витоках, однак через Еріеос легко пов'язується з реальним фото та Google-акаунтом.

		Рижченко Я.В.			ДУ «Житомирська політехніка».26.121.20.000 – Пр2	Арк.
		Лобанчикова Н.М.				5
Змн.	Арк.	№ докум.	Підпис	Дата		

Завдання 5. OSINT-розвідка по однокорупнику

Об'єкт дослідження: Семенчук Олексій Андрійович, нікнейм - FearlessAtom, email - ipz231_soa@student.ztu.edu.ua

Інструмент	Що перевірялося	Адреса
WhatsMyName	Нікнейм DDXwild	whatsmyname.app
HaveIBeenPwned	ipz231_ryav@student.ztu.edu.ua	haveibeenpwned.com
Epieos	ipz231_ryav@student.ztu.edu.ua	epieos.com

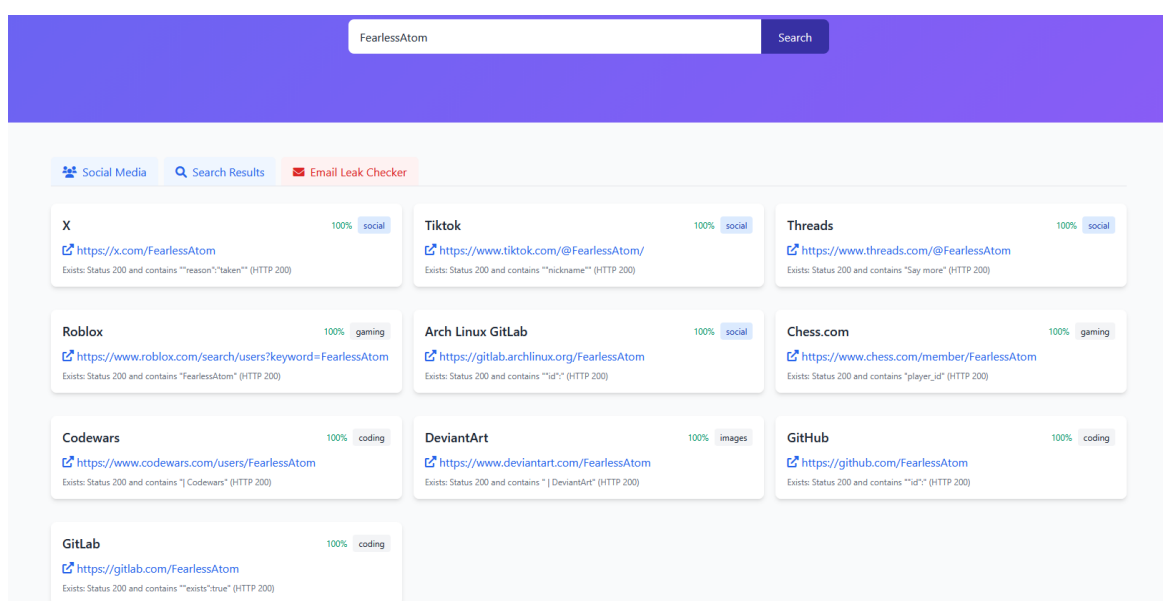


Рис. 4. Результат перевірки на сайті whatsmyname.app за нікнеймом FearlessAtom.

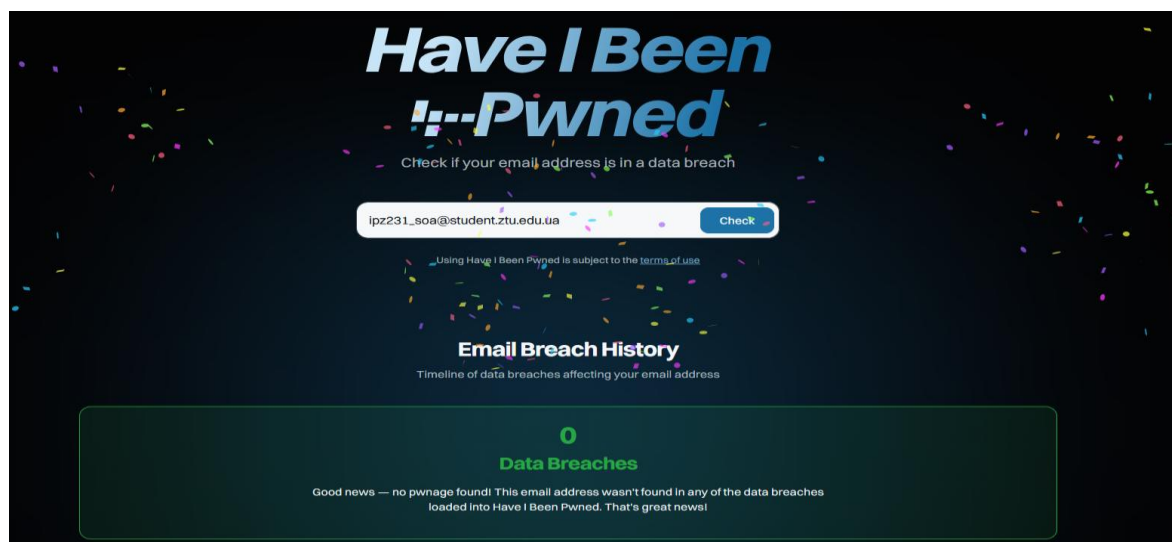


Рис. 3. Результат перевірки на сайті haveibeenpwned.com за поштою університету.

		Рижченко Я.В.			ДУ «Житомирська політехніка».26.121.20.000 – Лр2	Арк.
		Лобанчикова Н.М.				6
Змн.	Арк.	№ докум.	Підпис	Дата		

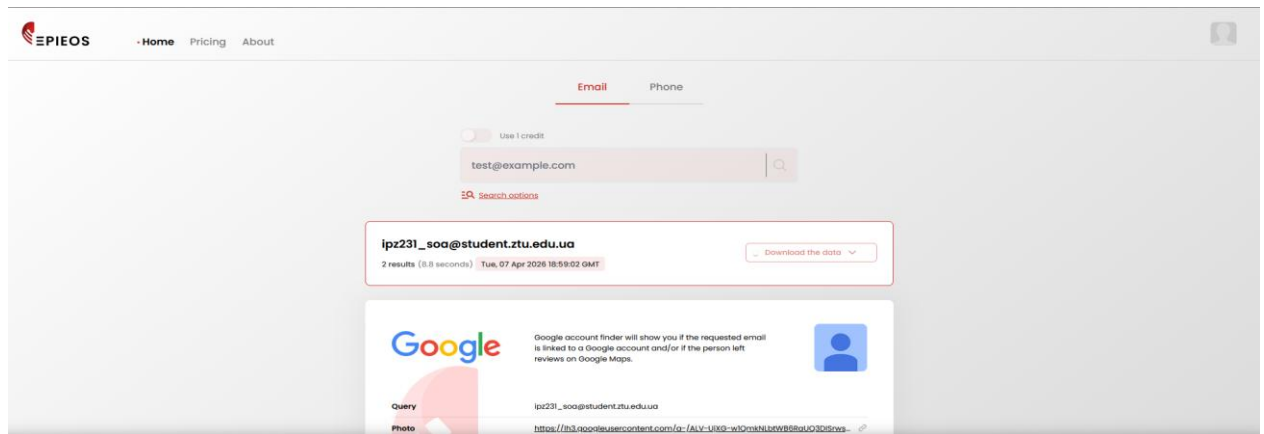


Рис. 3. Результат перевірки на сайті erieos.com за поштою університету.

За допомогою WhatsMyName виявлено акаунти під нікнеймом FearlessAtom на таких платформах: X (Twitter), TikTok, Threads, Roblox, Arch Linux GitLab, Chess.com, Codewars, DeviantArt, GitHub, GitLab. Платформи охоплюють соціальні мережі, ігрові сервіси, кодингові та творчі платформи. Інструмент Epieos для адреси ipz231_soa@student.ztu.edu.ua повернув 2 результати: виявлено прив'язку до Google-акаунту. На відміну від першого об'єкта, фото профілю не відображається (стандартна аватарка).

Оцінка: цифровий слід є ширшим - 10 платформ проти 8. Особливо показовою є присутність на DeviantArt та TikTok, що розширює можливості для збору візуальної та поведінкової інформації. Наявність акаунтів на GitHub та GitLab може додатково розкривати технічні навички та проєкти особи.

Завдання 6. Спільна оцінка та рекомендації

Що виявлено по обох об'єктах:

Обидва учасники мають помітний цифровий слід через нікнейми. DDXwild присутній на 8 платформах, FearlessAtom - на 10. В обох випадках студентська email-адреса у форматі ipz231_XXX@student.ztu.edu.ua легко виявляється через Epieos і прив'язана до Google-акаунту, що розкриває фото або особисті дані. Спільною рисою є присутність на Chess.com та Arch Linux GitLab, що дозволяє встановити зв'язок між акаунтами навіть без знання реального імені.

		Рижченко Я.В.			ДУ «Житомирська політехніка».26.121.20.000 – Пр2	Арк.
		Лобанчикова Н.М.				7
Змн.	Арк.	№ докум.	Підпис	Дата		

Що становить загрозу:

- Студентська email-адреса розкриває навчальний заклад, групу та ініціали особи вже через свій формат
- Eprints дозволяє прив'язати email до реального фото та Google-профілю без будь-яких технічних засобів
- Широка присутність однакового нікнейму на різних платформах дозволяє легко кросувати дані
- Акаунти на GitHub/GitLab можуть розкривати технічну діяльність, навчальні проєкти, можливо - фрагменти коду з чутливими даними

Зміни, що потрібно впровадити заради кращого захисту:

- Не використовувати один і той самий нікнейм на всіх платформах - це критично спрощує OSINT-розвідку
- Перевірити та обмежити видимість профілів на всіх виявлених платформах, особливо на TikTok, DeviantArt та Threads
- Видалити або деактивувати акаунти, якими не користуєтесь (Sourceforge, Donation Alerts тощо)
- Не прив'язувати студентський email до зовнішніх сервісів - використовувати окрему адресу без особистих даних
- Перевірити GitHub/GitLab репозиторії на наявність у коді особистих даних, паролів або токенів
- Використовувати унікальні паролі та менеджер паролів для кожного сервісу

Висновок: Лабораторна робота продемонструвала, наскільки багато інформації про людину або організацію можна зібрати з відкритих джерел без жодних спеціальних технічних засобів. Експеримент Вінклера залишається актуальним: соціальна інженерія досі є одним з найефективніших методів атаки, а основним захистом від неї є обізнаність персоналу та чіткі регламенти роботи з інформацією. OSINT-розвідка по власних даних показала реальний стан цифрового сліду та дала змогу виробити конкретні рекомендації щодо його зменшення.

		Рижченко Я.В.			ДУ «Житомирська політехніка».26.121.20.000 – Пр2	Арк.
		Лобанчикова Н.М.				8
Змн.	Арк.	№ докум.	Підпис	Дата		